



It's Coming From Inside the House: A Guide to Physical Penetration Testing

Ariyan Suroosh



Introductions

Ariyan Suroosh

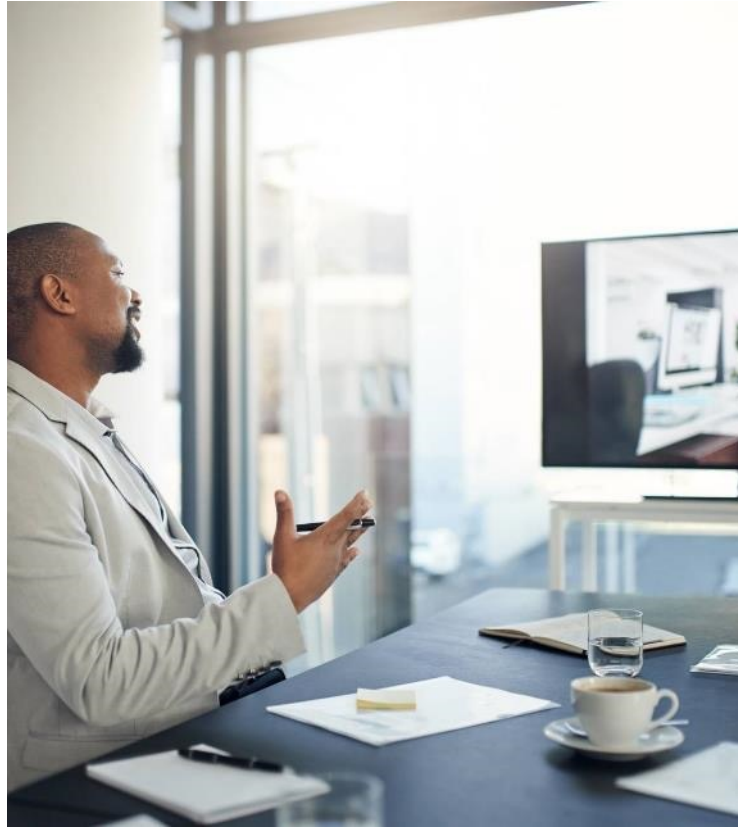
- Senior Security Consultant – Attack & Penetration at Optiv
- BS in Information Security
- Twitter: @pursuit_of_root





Agenda

- Client Expectations
- Remote Reconnaissance
- Onsite Reconnaissance
- Initial Access
- Badge Cloning
- Post Exploitation

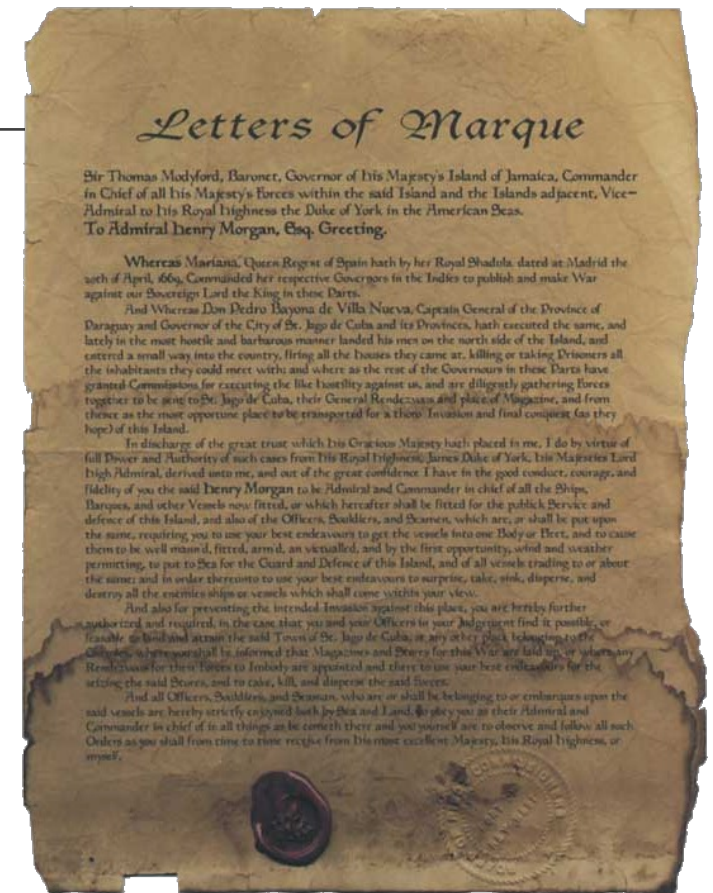


Client Expectations

What are their goals, their dos and their do nots?

Client Expectations

- This encompasses their goals and their limits
 - Discuss at length what they consider in scope and out of scope for:
 - Methods of access
 - Evidence to be collected
 - Hours
 - Interactions with employees
 - Criteria for success?
 - Set expectations for them as well
 - With the scope as written, what are they getting?
 - Ensure contacts will be available after-hours
 - What documents need to be provided and by when
 - Letter of Authorization (LOA) – Most important
 - Third-party consent form





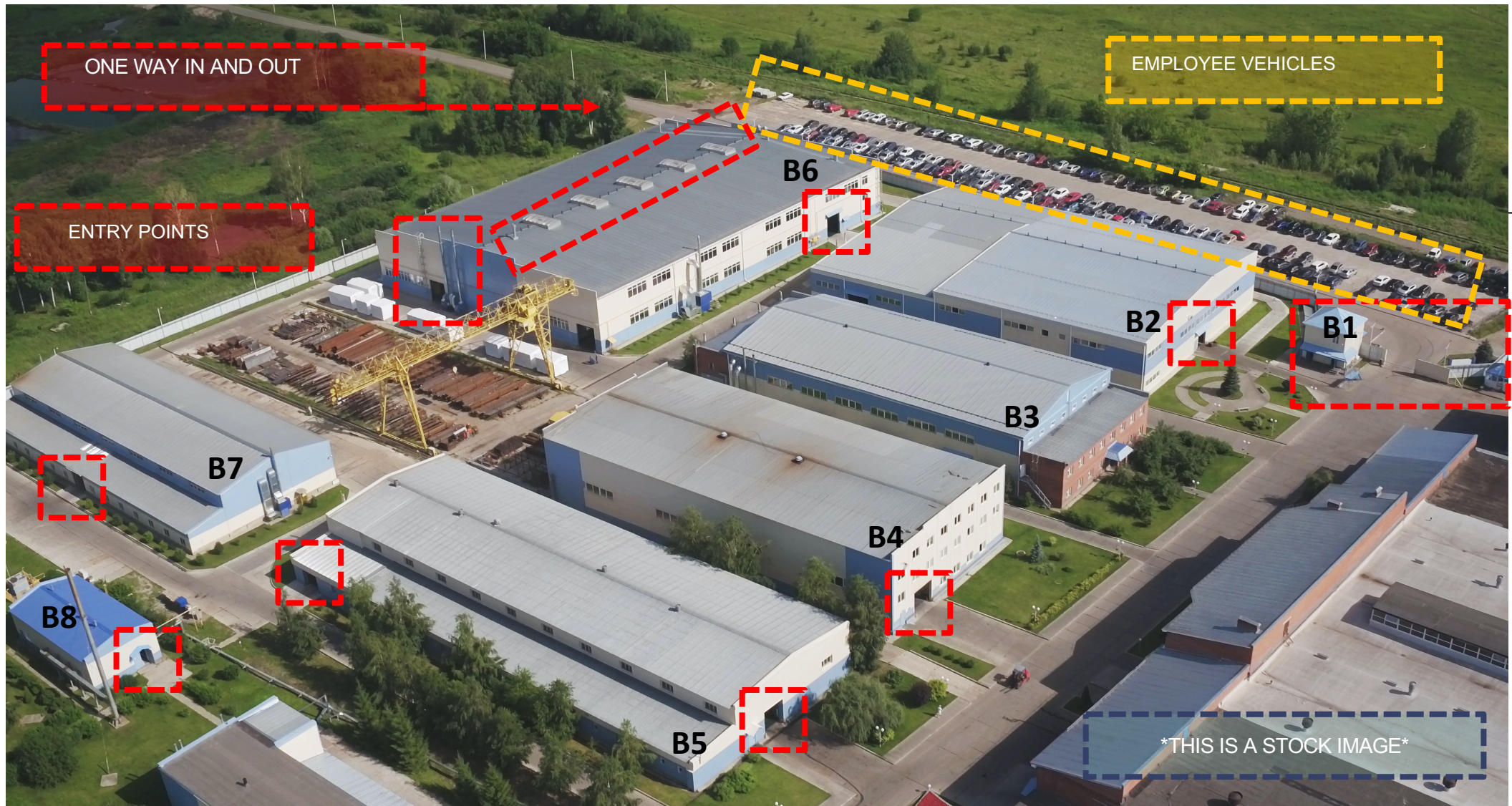
Remote Reconnaissance

Let's see what we're up against

Remote Reconnaissance

- Most important information gathering stage
 - What do their badges look like?
 - How do the employees dress?
- Satellite Images of their facility
 - Multitenant?
 - Gated Entry?
 - Directory?
 - What is the building surrounded by?
 - Where will you park for onsite recon?
 - Where are the entry points of the facility?
- Formulate plans A, B, and C
 - Have the initial vectors of compromise in mind and begin preparations
 - See an online store for uniforms? Excellent! Place the order well ahead of time







Onsite Reconnaissance

Let's confirm what we're up against, and bring that LOA

Onsite Reconnaissance



- Consists a lot of confirming what was discovered during the remote recon
 - Confirm/identify entry points
 - Confirm current dress code
 - Confirm badge information
- New Information
 - If no badge information was discovered, that's mission number 1 onsite
 - Observe how many employees appear to be coming/going and when
 - Identify most used entrances/exits
 - Identify break/ smoking areas
 - Observe security awareness culture, i.e. does one person hold the door open once badged for all others?
 - Have a drone? Now's your chance! (if you feel you must)

Onsite Reconnaissance - Tools

- Ultra Zoom Camera
 - Example: Nikon COOLPIX P1000
 - 125x optical zoom



Onsite Reconnaissance - Tools



Onsite Reconnaissance - Tools





Initial Access

What's the most likely plan to succeed?



Social Engineer /Tailgate



Surreptitious Entry

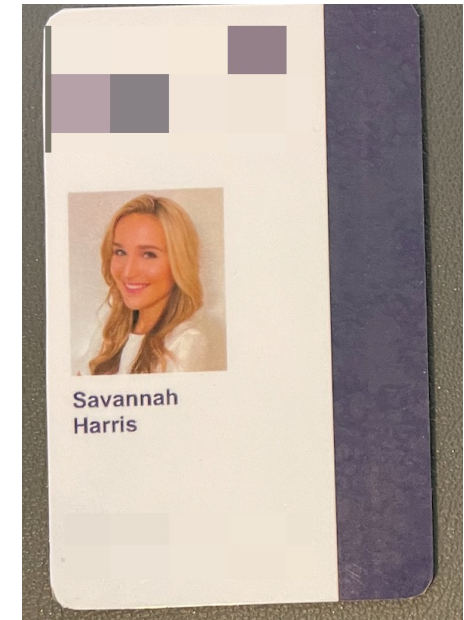
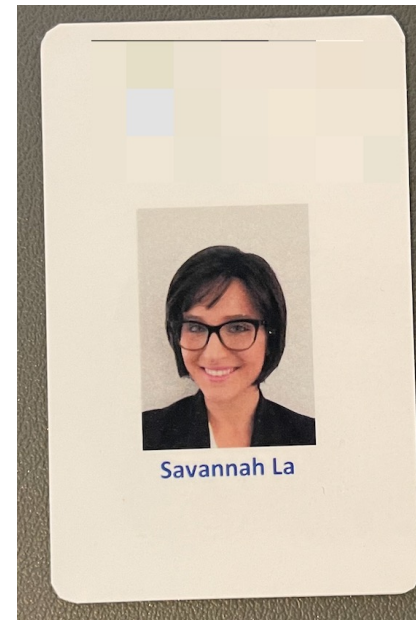


Authenticated Entry /
Badge Cloning



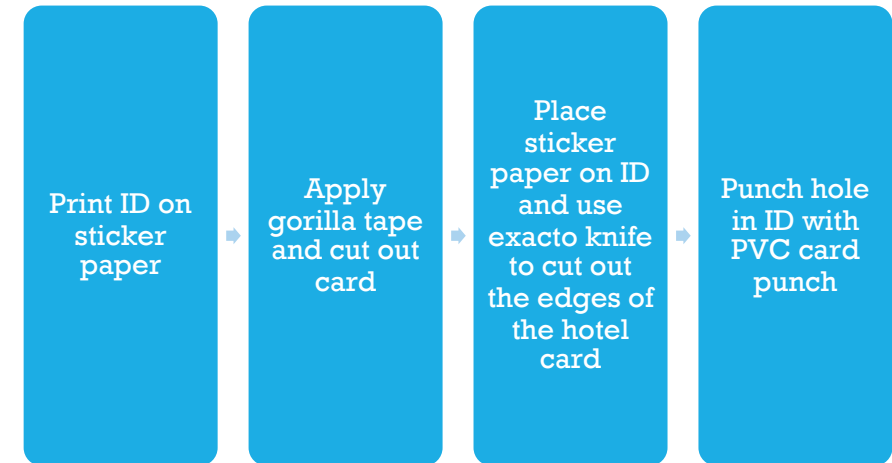
Social Engineer /Tailgate

Badge Replication (Not Cloning)



Badge Replication (Not Cloning)

- Spare hotel key / cloned HID card
- Badge clip or lanyard
- PVC card punch - \$10
- 8.5 x 11 sticker paper - \$4 per pack
- Scissors, knife, and/or razorblade
- Lobby printer or FedEx/Kinkos
- Optional: 3" Clear Gorilla tape - \$6 for a 2 pack at Home Depot (adds a glossy/weather resistant finish)



Pretexting / Tailgating

THINGS TO CONSIDER

- What will get you in the door?
 - Impersonate an employee or third party?
- What will allow you to walk around?
 - Time of day
 - Your pretext
- What will allow you to stay?
 - A little tougher to demonstrate impact while employees walk about
- Use real name?
 - Weirdly enough, you probably should

COME PREPARED

- Bring tools for interior door compromise
- Have phone settings that allow you to record everything you can, get time stamps for ingress/egress
 - Privacy screen
 - Dark display
- Long sleeves and layers whenever possible
- Keep an eye out for company polos/uniforms

LOOSEY-GOOSEY BABY

- Adapt. React. Readapt. Apt.
- Have a plan for getting turned down, getting turned away happens, but it mustn't be the end
- Has with other methods of entry, never be the person who knows anything. You're waiting on the person that knows what's going on

Pretexting/ Tailgating - Tools



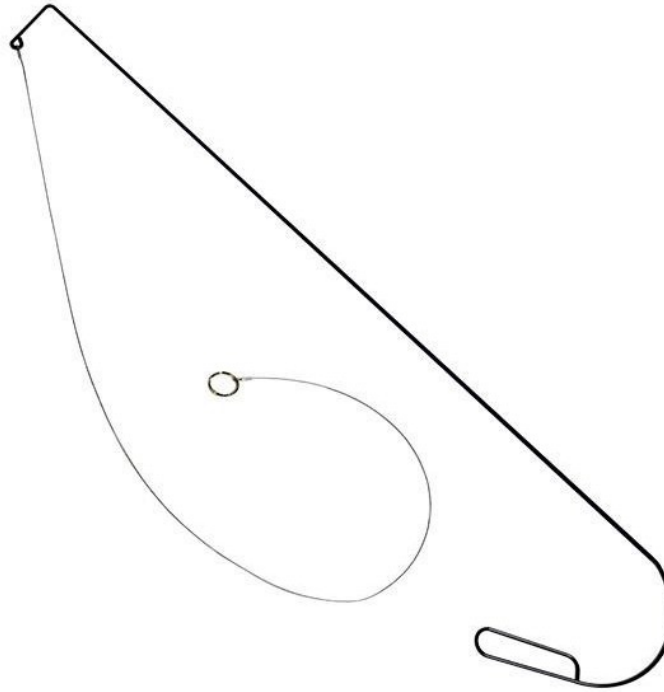


Surreptitious Entry

Surreptitious Entry

- If an option at all, its usually the best one in terms of risk and reward
 - Advantages:
 - Quickly determined to be possible or impossible
 - Usually very few, if any, staff onsite
 - Can carry out post-exploitation without resistance, including advanced network based onsite attacks (i.e. plug into network jack, carry out post-ex on open workstation, etc.)
 - Disadvantages
 - Can get caught in positions you cannot explain your way out of
 - Could involve police officers more often than other attacks
 - Right to jail right away
 - Considerations
 - Still dress with pretext in mind

Surreptitious Entry - Tools





Authenticated Entry /
Badge Cloning

Authenticated/ Badged Entry

- Devastating if successful
- Often grants a level of access above all other methods, especially when after-hours
- A few factors to consider if this is the best play
 - Requires environment that allows badge cloning pretexts
 - Walking around, getting close to people, possibly requiring multiple attempts
 - Post-Covid, that's more difficult due to employee population and heightened awareness of physical closeness
 - Is it even possible to clone?
 - Does this client have alerts set for badge swipes?
 - Recently released stealth reader evil twin can potentially alleviate many pain points

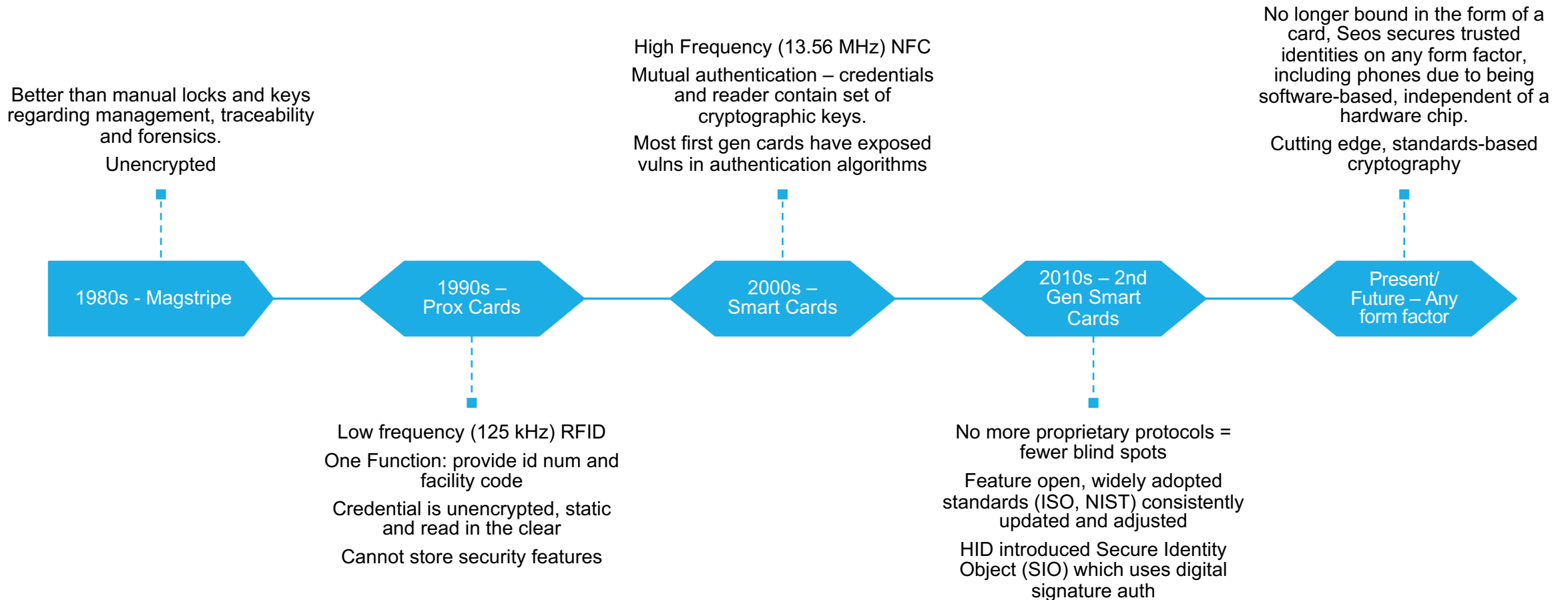
Authenticated/ Badged Entry

- Requires badge technology that is vulnerable to badge cloning
- This depends on many factors
 - Reader
 - Frequency
 - Credentials
 - Chipset
 - Format
- Trickier than getting a quick caveman eyeball on the badge reader

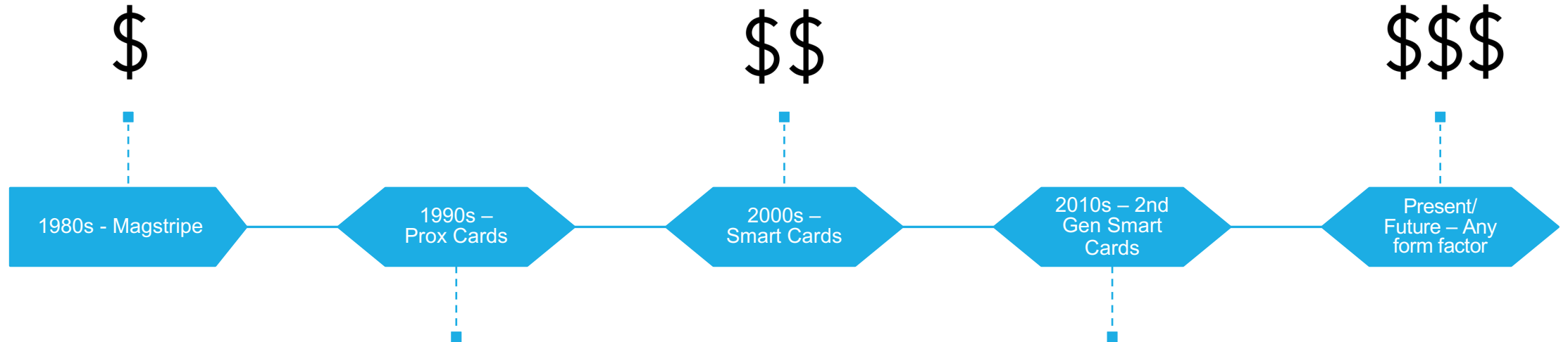
Authenticated/ Badged Entry

- Looking at the reader or badge does yield some information, but not as much as one might assume. HID provided a whitepaper with this explanation:
 - “This one-way flow of setup information from panel to card is intentional. It makes it difficult for an unauthorized person who finds a proximity card to know where and how to use it. Even a person with the technical knowledge and equipment cannot positively identify the card format. The reason is due to the format information residing in the panel and not on the card. A format is not a number — it is a way of looking at a number. The card data merely conforms to the panel format.”

Credential Technology Timeline



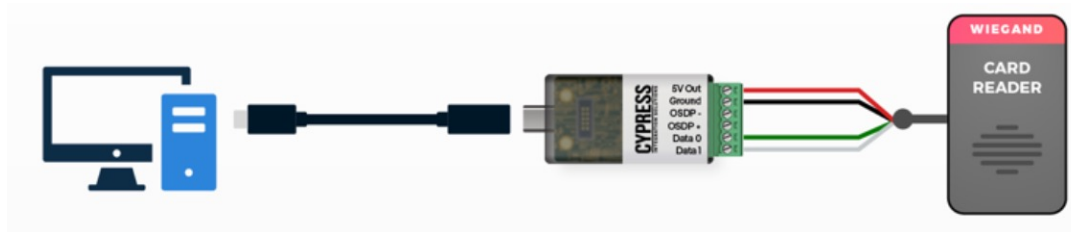
Credential Technology Timeline



ACS/Reader Technology Timeline

Reliable, weather resistant
Unsupervised
Lacks security protocols
Unilateral Communication

1980s - Wiegand

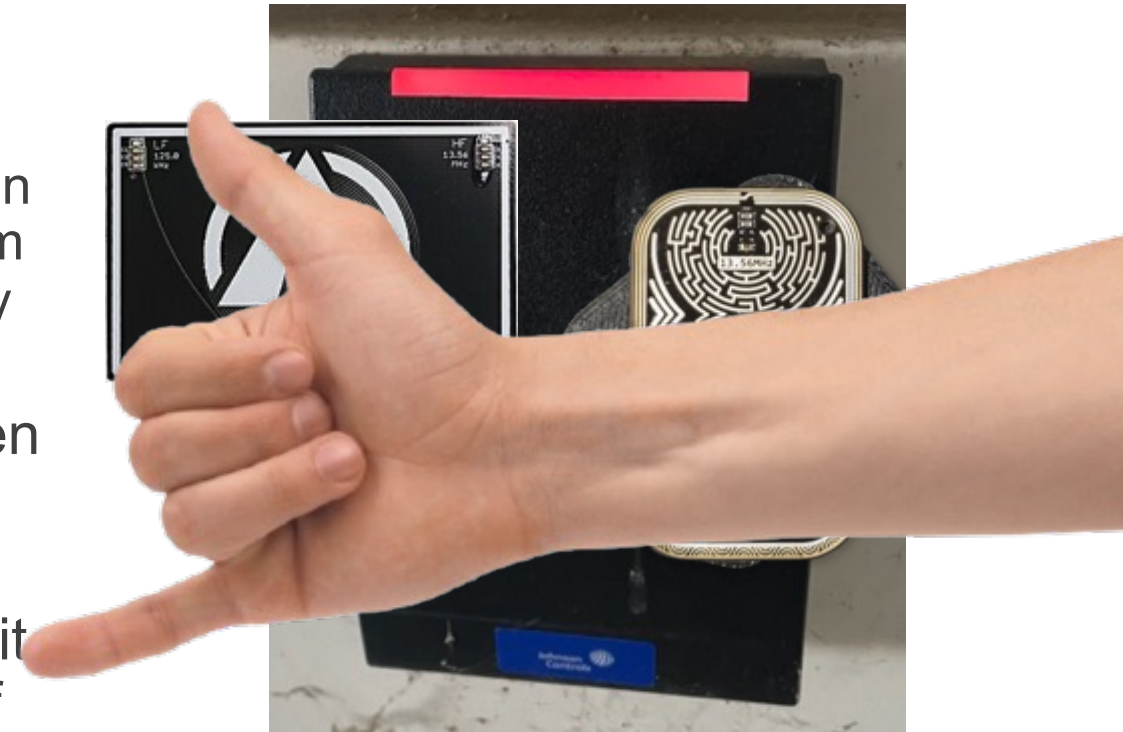


Present/future -
OSDP

Open Supervised Device Protocol
AES 128-bit Encryption
Bidirectional Communication

Authenticated/ Badged Entry

- What can we tell from looking at this reader?
 - In this example: multiCLASS SE= migration reader. Company is likely transitioning from older gen 1 smart cards and low frequency to gen 2 high frequency
- Looking at the accepted frequencies is often the most insightful information you'll get
- Use Proxgrind keychain or Dangerous Things card to determine which frequency it accepts. (Or left arm frequency detectors if you're us.)



Badge Cloning – Frequency Types

LOW FREQUENCY

- 125 kHz
- Lower frequencies carry less data
- Trivial to clone
- Older technology = cheaper
- Still very common

HIGH FREQUENCY

- 13.56 MHz
- Higher frequency carry more data
- Some can be cloned, most cannot
- Newer technology = more expensive
- More secure due to supporting cryptography

Badge Cloning – Portable Long-Range Readers

HID PROXIMITY MAXIPROX 5375



HID R90 ICLASS READER



Badge Cloning – Backend Firmware/Hardware



- Developed by Travis Weathers from PhysicalExploit.com
- Designed to run on the cheap and (especially at the time) much easier to get, *Thing Plus* ESP32 WROOM Dev Board
- Streamlined, modern WebGUI with options for downloading complete data sets
- Wireless Config Manager
- Email/text notifications
- Web application-based reset functionality



Badge Cloning – Backend Firmware/Hardware



- Straight forward to implement (Now)
- Backend cheap, reader incredibly expensive (800+)
- Comes in plug-n-play option from physicalexloit.com



Badge Cloning – Getting the Read

POUND THE PAVEMENT

- Select a reader and head out
- You have the reader and like nothing else.
- You have to be clooose. P bag on badge contact.



Badge Cloning – An Arguably Worse Alternative

LET THE READER DO THE READER DO
THE WORK AND DAMAGE WIRES DOIN IT

- Insert an ESPkey Wiegand Interception Tool into badge reader.
 - Collects credentials while you sip on fine cognacs
- **HUGE DOWNSIDE!!!**
 - Tool connects with an insulation-displacement contact (IDC) or insulation-piercing contact (IPC) and this does damage the wires. MUST GET EXPLICIT CLIENT APPROVAL
- Approval is Super rare, so that's all we'll cover for this topic



Badge Cloning – Physical Evil Twin

LET AN EVIL READER DO THE WORK AND DAMAGE NOTHING!

- Also developed by Travis Weathers of PhysicalExploit.com
- Green light and beep as any genuine reader would
- Supports iCLASS SE, SEOS, iCLASS SR, Standard iCLASS, HID, AWID, EM4102, Prox Credentials, and others
- Enable or disable WiFi at your convenience, effectively avoiding detection by wireless detective controls



Badge Cloning – Key Terms

CARD CREDENTIALS

- Refers to the method of authentication as well as the more specific variety in use. For example, badges and fobs are two different credentials

CARD CHIPSETS

- Credentials also refers to the type of card or fob used i.e. Prox, iCLASS, MIFARE, Indala. However, these names are more correctly referred to as the chipset in use. So MIFARE Classic 1k, 4k, ultralight, all chipset types

CARD FORMATS

- How the system interprets the information on the card.
- Just as a string of numbers like 19896780058 may mean nothing until you are told it's a phone number. Then you can understand

Badge Cloning – Cloneable Card Types

- Most cards ship out of the factory with privileges for its UID sector, most of the time sector 0, set to read only. Sector 0 containing manufacturing information as well as a 4 byte non-unique ID/ serial number of the chip. Examples:
 - MIFARE CLASSIC® 1k “Magic” Card
 - T5577 Chipset
 - HID Prox
 - HID ProxCard II
 - EM4100
 - Indala

Badge Cloning – Cloning iCLASS Badge

- How can we still clone iCLASS?
 - iCLASS has encryption and mutual authentication, but the master authentication key used by every iCLASS reader is retrievable, rendering their defenses untenable.
- What about iCLASS SE?
 - It is sometimes possible to read an iCLASS SE badge with the long-range reader and write the FC and ID to an iCLASS badge. Building readers are usually configured to accept both and won't distinguish between the two. If the FC and ID match, it will usually work.

Badge Cloning – Writing Credentials

- Obviously, could be its own talk entirely
- Lots of options, tools vary wildly in terms of:
 - Cost
 - Ease of use/available documentation
 - Capability
 - Situational use cases





Post- Exploitation

You made it in, how will you demonstrate impact?

Post-Exploitation

EVIDENCE

- Log time stamps for entry, exit, and in between
- Collect photos of areas you accessed, both benign and sensitive.

IMPACT

- Client's criteria for success
 - Payload?
 - Network access?
 - Just entry?
- Maximum allowable impact is the goal

EGRESS

- Its not a success until you get out
- Don't get too carried away, get out when you achieve your goals, and sometimes before then
- Leave nothing less secure than when you went in

Summary

This is more of an art than
a science to be sure.

Take your time

Get into character

Remember your LOA





Acknowledgements

Thank you!

Savannah Lazzara

Travis Weathers

Matt Burch

Nick Popovich

Hao Nguyen

DangerousThings

Covert Instruments

DeviantOllam

Iceman

References

- <https://www.hidglobal.com/sites/default/files/hid-understanding-corp1000-wp-en.pdf>
- https://www.hidglobal.com/sites/default/files/hid-understanding_card_data_formats-wp-en.pdf
- http://www.pagemac.com/projects/rfid/hid_data_formats
- <https://bookstack.optivlabs.com/books/physical-facility-penetration-test/page/badge-cloning#bkmrk-card-data-formats>
- <https://www.digitalid.co.uk/blog/hid-card-types>
- <https://tagbase.ksec.co.uk/resources/magic-uid/>
- <https://get.meriac.com/docs/HID-iCLASS-security.pdf>
- <https://blog.kchung.co/reverse-engineering-hid-iclass-master-keys/>
- <https://github.com/optiv/doppelganger?tab=readme-ov-file>
- <https://store.physicalexloit.com/products/ghost-reader?variant=48388730749241>
- <https://github.com/iceman1001>